

SIMATS ENGINEERING

ASSESSMENT TOOL 2 – APPLICATION-BASED QUESTIONS (High)

1. Exploitation of RPC Vulnerabilities in Legacy Windows Servers

Introduction

Remote Procedure Call (RPC) allows Windows systems and applications to communicate over a network. If RPC services are exposed and contain unpatched vulnerabilities, attackers may exploit them to gain unauthorized access, execute malicious code, or move through the internal network.

How attackers can exploit RPC vulnerabilities

Attackers can:

1. **Discover exposed RPC services** using network scanning and service enumeration.
2. Identify vulnerable or outdated RPC services and versions.
3. Exploit a known vulnerability to obtain **unauthorized access or remote code execution**.
4. Use the compromised server to obtain credentials or sensitive information.
5. Attempt **privilege escalation** to obtain administrator-level access.
6. Use the compromised system for **lateral movement** to other Windows servers.
7. Establish persistence and potentially steal financial or customer data.

Risk of delaying patches

The risk is **high to critical** because:

- Known vulnerabilities may already have publicly available exploits.
- Legacy systems may have weak security controls.

- A compromised server can become a starting point for lateral movement.
- Financial organizations contain highly valuable information.
- Delayed patching increases the attack window.

The observed abnormal traffic and unauthorized connection attempts make the situation more serious because they may indicate active reconnaissance or attempted exploitation.

Immediate patching vs controlled maintenance

Immediate patch deployment is preferred for actively exploited or critical RPC vulnerabilities. However, financial systems may require testing before changes are made.

A suitable approach is:

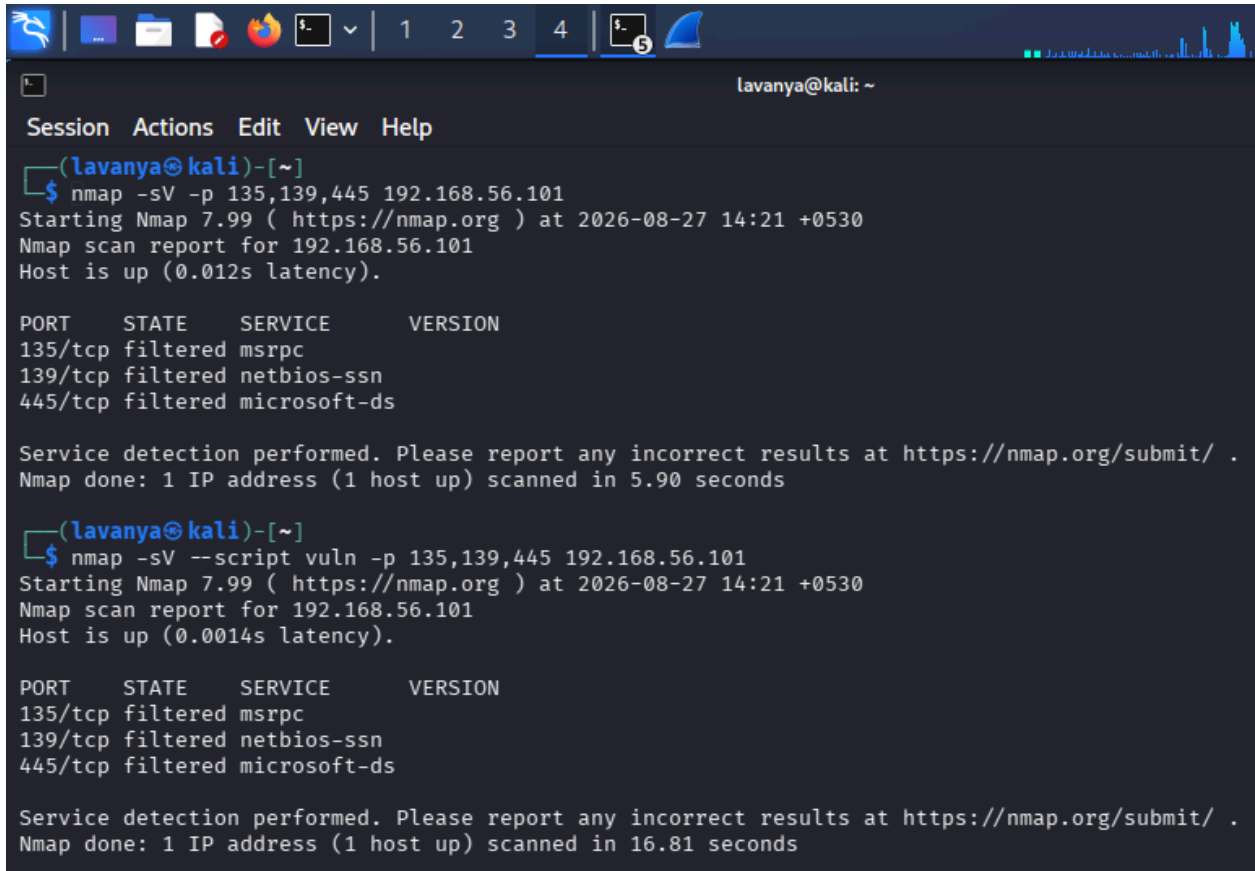
- Immediately isolate highly vulnerable servers where possible.
- Test patches in a staging environment.
- Apply emergency patches to critical systems during a controlled maintenance window.
- Monitor systems closely after patching.

Mitigation strategies

- Apply security patches and updates regularly.
- Disable unnecessary RPC services.
- Restrict RPC access using firewalls and network ACLs.
- Segment critical servers from normal user networks.
- Use strong administrator authentication.
- Monitor RPC traffic and authentication attempts.
- Deploy IDS/IPS and endpoint security.
- Maintain regular backups.
- Implement vulnerability scanning and patch-management policies.

Conclusion

Delaying critical RPC patches creates a **high security risk**. The organization should prioritize critical patching while using controlled testing and maintenance procedures to minimize business disruption.



```
lavanya@kali: ~  
Session Actions Edit View Help  
(lavanya@kali)-[~]  
$ nmap -sV -p 135,139,445 192.168.56.101  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:21 +0530  
Nmap scan report for 192.168.56.101  
Host is up (0.012s latency).  
  
PORT      STATE      SERVICE      VERSION  
135/tcp    filtered  msrpc  
139/tcp    filtered  netbios-ssn  
445/tcp    filtered  microsoft-ds  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 5.90 seconds  
  
(lavanya@kali)-[~]  
$ nmap -sV --script vuln -p 135,139,445 192.168.56.101  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:21 +0530  
Nmap scan report for 192.168.56.101  
Host is up (0.0014s latency).  
  
PORT      STATE      SERVICE      VERSION  
135/tcp    filtered  msrpc  
139/tcp    filtered  netbios-ssn  
445/tcp    filtered  microsoft-ds  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 16.81 seconds
```

2. XSS, CSRF and Weak Session Management in a Web Application

Introduction

XSS, CSRF, and weak session management are serious web application vulnerabilities. When attackers combine them, they can compromise user sessions and perform unauthorized actions on behalf of legitimate users.

How attackers can combine the vulnerabilities

An attacker may:

1. Find an **XSS vulnerability** in the application.
2. Inject malicious JavaScript into a vulnerable page.
3. When a victim accesses the page, the script executes in the victim's browser.
4. If session management is weak, the attacker may abuse the victim's active session.
5. CSRF can then be used to cause the victim's authenticated browser to perform unauthorized actions.
6. The attacker may target sensitive functions such as account changes or financial transactions.

For example, an attacker could trick an authenticated user into visiting a malicious page. If the application does not properly validate requests and sessions, an unauthorized transaction could potentially be performed using the user's privileges.

Risks of poor session management

Weak session management can lead to:

- Session hijacking
- Account takeover
- Unauthorized transactions
- Credential theft
- Session fixation
- Long-lived stolen sessions
- Unauthorized access to personal information

Risks of poor input validation

Poor input validation allows attackers to insert malicious data into application inputs. This can result in:

- XSS attacks
- Data manipulation
- Malicious script execution
- Account compromise

- Loss of user trust

Need for layered security

A single security mechanism cannot protect the application from all attacks.

Defense in depth is required.

For example:

**Input validation → Output encoding → Secure sessions → CSRF protection
→ Authentication → Authorization → Monitoring**

If one security layer fails, other layers can still reduce the impact.

Mitigation strategies

- Validate and sanitize user input.
- Apply proper **output encoding** to prevent XSS.
- Use **Content Security Policy (CSP)**.
- Use anti-CSRF tokens for state-changing requests.
- Use **Secure**, **HttpOnly**, and appropriate **SameSite** cookie attributes.
- Generate strong, unpredictable session IDs.
- Regenerate session IDs after authentication.
- Implement session expiration and logout.
- Use HTTPS throughout the application.
- Implement MFA for sensitive accounts.
- Apply proper authorization checks on every sensitive operation.
- Log and monitor suspicious transactions.

Conclusion

The combination of XSS, CSRF, and weak session management can result in **account takeover and unauthorized transactions**. A layered security approach is therefore essential to protect users and financial operations.

```
Session Actions Edit View Help
Host is up (0.0012s latency).

PORT      STATE SERVICE      VERSION
80/tcp    closed http
443/tcp    closed https
5000/tcp   open  http         Werkzeug httpd 3.1.8 (Python 3.13.12)
8080/tcp   closed http-proxy

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.97 seconds

(lavanya@kali)-[~]
$ whatweb http://127.0.0.1:5000
http://127.0.0.1:5000 [200 OK] Country[RESERVED][ZZ], HTML5, HTTPServer[Werkzeug/3.1.8 Python/3.13.12], IP[127.0.0.1], Python[3.13.12], Title[NIDS ML Dashboard], Werkzeug[3.1.8]

(lavanya@kali)-[~]
$ curl "http://127.0.0.1:5000/search?q=%3Cscript%3Ealert(1)%3C/script%3E"
<!doctype html>
<html lang=en>
<title>404 Not Found</title>
<h1>Not Found</h1>
<p>The requested URL was not found on the server. If you entered the URL manually please check your spelling and try a gain.</p>

(lavanya@kali)-[~]
$ nikto -h http://127.0.0.1:5000
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 5000
+ Platform: Unknown
+ Start Time: 2026-08-27 14:24:34 (GMT5.5)

+ Server: Werkzeug/3.1.8 Python/3.13.12
+ ERROR: Failed to check for updates:
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, OPTIONS .
```

3. Outdated IIS Server with Critical Unpatched Vulnerabilities

Introduction

Internet Information Services (IIS) is a Windows web server used to host websites and applications. An outdated IIS server containing critical vulnerabilities can provide attackers with an entry point into an organization.

How attackers can exploit the vulnerabilities

Attackers can:

1. Identify the IIS server through reconnaissance and vulnerability scanning.

2. Determine the IIS version and exposed services.
3. Identify known vulnerabilities.
4. Exploit a vulnerable service or web application.
5. Obtain unauthorized access.
6. In severe cases, exploit a vulnerability that allows **remote code execution**.
7. Use the compromised server to access databases, credentials, or other internal systems.
8. Move laterally within the organization.

Risks of delaying updates

The risk is **high/critical** because:

- Critical vulnerabilities may already be publicly known.
- Attackers actively search for vulnerable Internet-facing servers.
- Successful exploitation can lead to remote code execution.
- A web server can provide access to sensitive backend systems.
- Delayed patching increases the organization's exposure period.

Immediate patching vs temporary isolation

For **critical vulnerabilities on an externally accessible IIS server**, immediate remediation should be prioritized.

If immediate patching cannot be performed safely, the organization should use **temporary isolation** as a short-term measure.

For example:

- Restrict Internet access.
- Place the server behind a firewall/WAF.
- Allow only required traffic.
- Increase monitoring.
- Schedule emergency patching as soon as possible.

Isolation should **not become a permanent replacement for patching**.

Strategies for security and availability

- Test patches in a staging environment.
- Maintain backups and recovery procedures.
- Use redundant servers where possible.
- Perform updates during controlled maintenance windows.
- Use load balancing to reduce downtime.
- Deploy a Web Application Firewall (WAF).
- Disable unnecessary services and modules.
- Restrict network access.
- Continuously monitor logs.
- Perform regular vulnerability assessments.
- Maintain an emergency patching procedure for critical vulnerabilities.

Conclusion

Because critical IIS vulnerabilities can potentially result in unauthorized access or remote code execution, **delaying updates creates significant risk**. Temporary isolation can protect the system while patching is prepared, but critical vulnerabilities should ultimately be patched as quickly as safely possible.


```
Session Actions Edit View Help
valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:91:c4:b2 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 83807sec preferred_lft 83807sec
    inet6 fd17:625c:f037:2:4874:7248:f03d:3379/64 scope global temporary deprecated dynamic
        valid_lft 86193sec preferred_lft 0sec
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86193sec preferred_lft 14193sec
    inet6 fe80::a00:27ff:fe91:c4b2/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(lavanya@kali)-[~]
$ nmap -sV -p 80,443 <IP>
bash: syntax error near unexpected token `newline'

(lavanya@kali)-[~]
$ nmap -sV -p 80,443 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:29 +0530
Nmap scan report for 192.168.1.10
Host is up (0.0059s latency).

PORT      STATE      SERVICE VERSION
80/tcp    filtered  http
443/tcp   filtered  https

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.86 seconds

(lavanya@kali)-[~]
$ nmap -sV -p 80,443 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:29 +0530
Nmap scan report for 192.168.1.10
Host is up (0.0030s latency).

PORT      STATE      SERVICE VERSION
80/tcp    filtered  http
443/tcp   filtered  https

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.44 seconds
```

4. Mobile Application Storing Sensitive Data in Plaintext

Introduction

Storing login credentials and personal information in plaintext on a mobile device is a major security weakness. Communication with backend servers over unsecured channels also allows attackers to potentially intercept sensitive information.

Exploitation through device compromise

If a device is compromised through malware, rooting, theft, or another attack, an attacker may access the application's local storage.

Plaintext data could expose:

- Usernames
- Passwords
- Personal information
- Authentication tokens
- Application data

If authentication information is stolen, attackers may potentially use it to access the user's account.

Exploitation through network interception

If the application communicates over an unsecured channel such as HTTP, attackers on the same or an otherwise compromised network may be able to intercept traffic.

This can lead to:

- Credential exposure
- Personal-data leakage
- Session/token theft
- Man-in-the-middle attacks
- Unauthorized account access

Impact on privacy

Exposure of personal information can result in:

- Identity theft
- Account compromise
- Financial loss
- Violation of privacy
- Loss of customer confidence

Impact on organizational reputation

A data breach can cause:

- Loss of customer trust
- Negative publicity
- Financial losses
- Regulatory consequences
- Damage to the organization's reputation

Need for encryption

Encryption protects information by converting readable data into an unreadable form.

Two important areas are:

Data at rest:

Sensitive information stored on the device should be encrypted.

Data in transit:

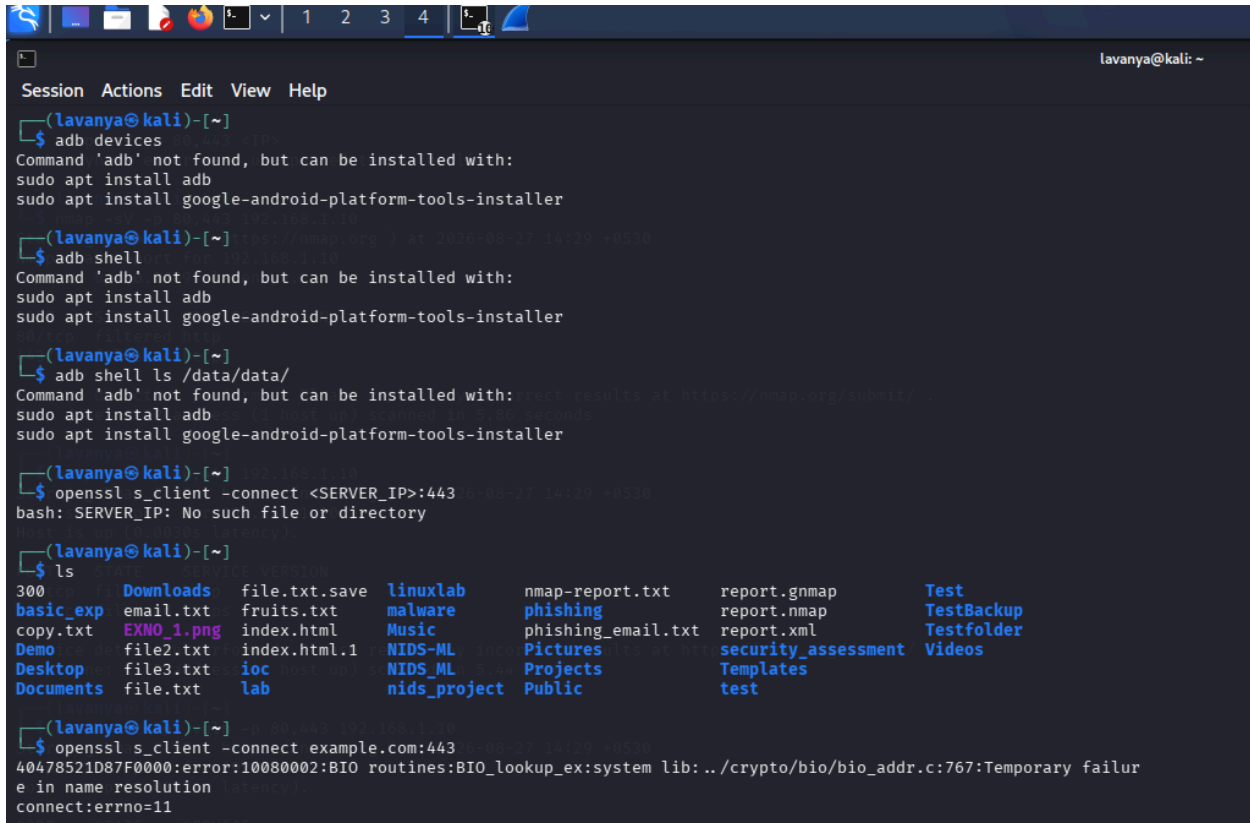
Communication between the mobile application and server should use secure encrypted protocols such as **HTTPS/TLS**.

Secure storage and communication techniques

- Never store passwords in plaintext.
- Use secure platform-provided storage mechanisms.
- Encrypt sensitive local data.
- Use HTTPS/TLS for all backend communication.
- Validate TLS certificates correctly.
- Avoid storing unnecessary sensitive information.
- Use short-lived authentication tokens.
- Protect tokens using secure storage.
- Apply strong authentication and MFA where appropriate.
- Implement secure logout and token invalidation.
- Regularly test the mobile application for security vulnerabilities.

Conclusion

Plaintext storage and unsecured communication create **high risks to user privacy and account security**. Encryption, secure storage, HTTPS/TLS, strong authentication, and secure coding practices should be implemented to protect sensitive information.



```
Session Actions Edit View Help
(lavanya@kali)-[~]
$ adb devices
Command 'adb' not found, but can be installed with:
sudo apt install adb
sudo apt install google-android-platform-tools-installer

(lavanya@kali)-[~]
$ adb shell
Command 'adb' not found, but can be installed with:
sudo apt install adb
sudo apt install google-android-platform-tools-installer

(lavanya@kali)-[~]
$ adb shell ls /data/data/
Command 'adb' not found, but can be installed with:
sudo apt install adb
sudo apt install google-android-platform-tools-installer

(lavanya@kali)-[~]
$ openssl s_client -connect <SERVER_IP>:443
bash: SERVER_IP: No such file or directory

(lavanya@kali)-[~]
$ ls
300      Downloads  file.txt.save  linuxlab  nmap-report.txt  report.gnmap  Test
basic_exp  email.txt  fruits.txt    malware   phishing         report.nmap   TestBackup
copy.txt  EXNO_1.png index.html    Music     phishing_email.txt  report.xml    Testfolder
Demo      file2.txt  index.html.1  NIDS-ML  Pictures         security_assessment  Videos
Desktop   file3.txt  ioc          NIDS_ML  Projects        Templates
Documents file.txt   lab          nids_project  Public          test

(lavanya@kali)-[~]
$ openssl s_client -connect example.com:443
40478521D87F0000:error:10080002:BIIO routines:BIIO_lookup_ex:system lib:../crypto/bio/bio_addr.c:767:Temporary failure
in name resolution
connect:errno=11
```

5. Windows Firewall Disabled During Troubleshooting

Introduction

A firewall controls incoming and outgoing network traffic based on security rules. Disabling the Windows firewall removes an important security layer and can expose services that would normally be protected.

How attackers can exploit the exposure

When the firewall is disabled, attackers may:

1. Discover exposed systems and services.
2. Identify open ports.
3. Attempt unauthorized connections.
4. Target vulnerable services.
5. Exploit weak authentication or vulnerable applications.
6. Gain unauthorized access if a vulnerable service is exposed.
7. Attempt privilege escalation or lateral movement.

The unauthorized connection attempts detected shortly after the firewall was disabled demonstrate why temporary security-control changes can create significant exposure.

Risks of mismanaging security controls

The risks include:

- Unauthorized network access
- Exploitation of vulnerable services
- Malware infection
- Data theft
- Privilege escalation
- Lateral movement
- Increased attack surface
- Loss of confidentiality, integrity, and availability

The major problem is not only disabling the firewall but **forgetting to restore the security control**.

Importance of automated policies

Automated security policies reduce dependence on human memory.

For example:

- Automatically re-enable the firewall after a defined period.
- Prevent permanent firewall disabling without authorization.

- Monitor firewall status centrally.
- Generate alerts when security controls are disabled.
- Use endpoint management to enforce security configurations.

Administrative safeguards

- Follow a formal change-management process.
- Require authorization before disabling security controls.
- Record all configuration changes.
- Use time-limited troubleshooting permissions.
- Automatically restore firewall settings.
- Monitor firewall status continuously.
- Generate alerts when the firewall is disabled.
- Apply least-privilege access.
- Conduct regular security audits.
- Train administrators about security-control management.
- Maintain incident-response procedures.

Conclusion

Disabling the firewall, even temporarily, can significantly increase the attack surface. **Security controls should never depend only on administrator memory.** Automated enforcement, monitoring, change management, and time-limited administrative access can reduce this type of incident while allowing troubleshooting to continue safely.

```
Session Actions Edit View Help
inet6 ::1/128 scope host noprefixroute
    valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:91:c4:b2 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 83430sec preferred_lft 83430sec
    inet6 fd17:625c:f037:2:4874:7248:f03d:3379/64 scope global temporary deprecated dynamic
        valid_lft 86171sec preferred_lft 0sec
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86171sec preferred_lft 14171sec
    inet6 fe80::a00:27ff:fe91:c4b2/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(lavanya@kali)-[~]
$ nmap -Pn -p 135,139,445 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:33 +0530
Nmap scan report for 192.168.1.10
Host is up (2.1s latency).

PORT      STATE      SERVICE
135/tcp   filtered  msrpc
139/tcp   filtered  netbios-ssn
445/tcp   closed    microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 23.59 seconds

(lavanya@kali)-[~]
$ nmap -sV -p 135,139,445 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:33 +0530
Nmap scan report for 192.168.1.10
Host is up (0.0030s latency).

PORT      STATE      SERVICE      VERSION
135/tcp   filtered  msrpc
139/tcp   filtered  netbios-ssn
445/tcp   filtered  microsoft-ds

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.61 seconds
```

```
(lavanya@kali)-[~]
$ nmap --script smb-vuln* -p 445 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:33 +0530
Nmap scan report for 192.168.1.10
Host is up (0.0018s latency).

PORT      STATE      SERVICE
445/tcp   filtered  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 4.47 seconds
```